

ISO/IEC 27001:2022 PRACTICAL CAPSTONE PROJECT

Building an Information Security Management System (ISMS) for PaySwift Ltd

Prepared By

Name: Samuel Chukwudi Nweke

Course: Governance, Risk and Compliance

Project Title: Practical Capstone Project: ISO 27001 Implementation and Internal Audit for PaySwift Ltd

Roles Assumed

- Junior GRC Analyst
- Internal ISO/IEC 27001 Auditor

Organization: PaySwift Ltd (Fictional Case Study)

Submitted To

Instructor: Glory Odeli

Submission Date: 8 August, 2026.

Project Overview

This capstone project demonstrates the practical application of **ISO/IEC 27001:2022** principles within a realistic business environment. Acting as both a **Junior GRC Analyst** and an **Internal ISO/IEC 27001 Auditor**, the objective is to assist **PaySwift Ltd**, a growing fintech organization, in establishing an **Information Security Management System (ISMS)** and assessing its readiness for ISO/IEC 27001 certification.

The project applies **Governance, Risk, and Compliance (GRC)** concepts to identify information security risks, recommend appropriate security controls, develop essential ISMS documentation, and evaluate organizational compliance against the requirements of **ISO/IEC 27001:2022**.

ISO/IEC 27001 Practical Capstone Project

Prepared in partial fulfillment of the requirements for the ISO/IEC 27001:2022 Information Security Management System (ISMS) Training Program. The next section is the Table of Contents.

Table of Contents

ISMS Scope Definition for PaySwift Ltd

Identification of Interested Parties for PaySwift Ltd's Information Security Management System (ISMS)

Information Security Risk Assessment for PaySwift Ltd

Information Security Risk Treatment Plan for PaySwift Ltd

Selection of ISO/IEC 27001:2022 Annex A Controls for PaySwift Ltd

Statement of Applicability (SoA) PaySwift Ltd – Information Security Management System (ISMS)

Information Security Objectives for PaySwift Ltd

ISO/IEC 27001 Certification Audit Preparation – Evidence Collection for PaySwift Ltd

Internal ISO/IEC 27001 Audit Assessment – PaySwift Ltd

Internal Auditor Recommendation for ISO/IEC 27001 Certification Recommendation

Information Security Management System (ISMS) Scope Definition for PaySwift Ltd

Purpose

This document defines the scope of the Information Security Management System (ISMS) for **PaySwift Ltd** in accordance with the requirements of **ISO/IEC 27001:2022**. The scope establishes the boundaries of the ISMS by identifying the systems, processes, people, and information assets that support the organization's mobile payment services and the protection of sensitive information.

ISMS Scope Statement

The ISMS applies to all systems, business processes, personnel, and information assets involved in the development, operation, and support of PaySwift Ltd's mobile payment services. It includes on-premises and cloud-based environments, employees, contractors, and third-party providers that process, store, or manage company information.

Systems Included

The ISMS covers the following systems:

- Customer mobile payment application
- Microsoft 365 environment (Outlook, Teams, SharePoint, and OneDrive)
- Amazon Web Services (AWS) cloud infrastructure
- Corporate laptops, desktops, and authorized mobile devices
- Internal networks, VPNs, and remote access solutions
- Identity and Access Management (IAM) systems
- Backup and disaster recovery systems
- Security monitoring and logging systems

Business Processes Included

The ISMS applies to the following key business and security processes:

- Payment transaction processing
- Customer data collection, storage, and management
- User access management
- Information security incident management

- Risk assessment and risk treatment
- Change management
- Backup and recovery
- Vendor and third-party management
- Employee onboarding and offboarding
- Business continuity and disaster recovery planning
- Information security awareness and training

People Included

The ISMS applies to:

- Executive management
- All employees (approximately 50 staff)
- Remote and hybrid workers
- IT and information security personnel
- Contractors and consultants with authorized access
- Third-party service providers handling company information

Information Assets Included

The following information assets fall within the ISMS scope:

- Customer personal information
- Payment and transaction records
- Financial information
- Employee records
- Business documents and communications
- Source code and application data
- Security logs and audit records
- Configuration files and system documentation
- Data stored in Microsoft 365 and AWS cloud environments

Recommended Exclusions

The following areas may be excluded from the ISMS, provided they do not process or store organizational information:

- Personal devices not authorized under the Bring Your Own Device (BYOD) policy
- Personal email accounts and unapproved cloud storage services
- Office facilities and equipment unrelated to information processing, such as kitchen facilities and general building maintenance systems

All exclusions must be documented, justified, and periodically reviewed to ensure they do not introduce unacceptable information security risks.

Justification

The proposed scope includes all critical systems, personnel, processes, and information assets that support PaySwift Ltd's mobile payment services and the protection of customer and financial information. As a fintech organization, safeguarding the confidentiality, integrity, and availability of information is essential for maintaining customer trust, meeting regulatory obligations, and achieving ISO/IEC 27001 certification.

Remote and hybrid workers are included because they routinely access corporate systems outside the office environment. Likewise, Microsoft 365 and AWS are essential components of the organization's technology infrastructure and are therefore within the ISMS scope. The recommended exclusions are limited to assets that have no direct involvement in information processing, helping reduce unnecessary complexity while maintaining effective security controls.

Risks of a Narrow ISMS Scope

Defining the ISMS scope too narrowly can expose the organization to significant security and compliance risks. Critical systems, business processes, or third-party services may be excluded from security controls, increasing the likelihood of cyberattacks, data breaches, unauthorized access, and operational disruptions.

A limited scope may also result in nonconformities during ISO/IEC 27001 certification audits if it does not accurately represent the organization's operations. Furthermore, excluding critical assets or processes can lead to inconsistent security practices, regulatory non-compliance, financial losses, and reputational damage.

Conclusion

The proposed ISMS scope provides comprehensive coverage of the systems, processes, personnel, and information assets that support PaySwift Ltd's mobile payment services. By clearly defining the scope, the organization establishes a strong foundation for effective information security management, regulatory compliance, business resilience, and successful ISO/IEC 27001:2022 certification.

Identification of Interested Parties for PaySwift Ltd's Information Security Management System (ISMS)

Introduction

As part of the implementation of the **ISO/IEC 27001:2022 Information Security Management System (ISMS)**, PaySwift Ltd has identified the internal and external interested parties that can influence, or be affected by, its information security activities. Clause 4.2 of ISO/IEC 27001:2022 requires organizations to determine these interested parties and understand their relevant needs and expectations.

Identifying interested parties enables PaySwift Ltd to align its information security objectives with business goals, legal and regulatory obligations, customer expectations, and industry best practices. Understanding these requirements also supports effective risk management, governance, compliance, and continual improvement of the ISMS.

Identification of Interested Parties

Interested Party	Importance to the Organization	Information Security Needs and Expectations
Customers	Customers are the primary users of PaySwift Ltd's mobile payment services and entrust the organization with sensitive personal and financial information. Their confidence is essential to the company's reputation, customer retention, and long-term success.	Protection of personal and financial data, secure payment processing, privacy, confidentiality, high service availability, and timely response to security incidents.
Employees (Including Remote and Hybrid Workers)	Employees access and manage organizational systems on a daily basis. Their activities directly influence the confidentiality, integrity, and availability of company information.	Clearly documented security policies, ongoing security awareness training, secure remote access, appropriate access privileges, secure devices, and protection of employee information.

Management and Executive Leadership	Senior management is responsible for establishing the ISMS, allocating resources, managing organizational risks, and ensuring compliance with ISO/IEC 27001 requirements.	Effective governance, risk management, regulatory compliance, business continuity, protection of organizational assets, successful ISO/IEC 27001 certification, and regular reporting on ISMS performance.
Regulators and Government Authorities	As a fintech organization processing financial and personal information, PaySwift Ltd must comply with applicable laws, regulations, and data protection requirements.	Compliance with legal and regulatory obligations, protection of customer information, secure record management, incident reporting where required, and implementation of appropriate security controls.
Business Partners and Third-Party Service Providers	PaySwift Ltd relies on cloud providers, software vendors, payment processors, and technology partners to support critical business operations. Their security practices directly affect the organization's security posture.	Secure data sharing, clearly defined security responsibilities, contractual compliance, protection of shared information, timely notification of security incidents, and effective third-party risk management.
Cloud Service Providers (Microsoft 365 and AWS)	Microsoft 365 and Amazon Web Services (AWS) host essential business applications, collaboration platforms, and sensitive organizational data. Their services are critical to business continuity and secure remote operations.	Secure integration, effective identity and access management, compliance with contractual obligations, continuous monitoring, secure configuration, and adherence to the shared responsibility model for cloud security.
Auditors and Certification Bodies	External auditors evaluate the effectiveness of the ISMS and determine whether the organization meets the requirements for ISO/IEC 27001 certification.	Complete and accurate documentation, evidence of implemented security controls, effective risk management processes, continual improvement of the ISMS, and compliance with ISO/IEC 27001:2022 requirements.

Summary

Identifying interested parties enables PaySwift Ltd to understand the expectations of individuals and organizations that influence or are affected by its Information Security Management System.

Customers expect their personal and financial information to be protected through secure payment services and robust privacy controls. Employees require secure systems, clearly defined security policies, appropriate access controls, and ongoing security awareness training to perform their responsibilities safely. Management expects effective governance, proactive risk management, regulatory compliance, and business continuity to support organizational objectives.

Regulators and government authorities require compliance with applicable legal, financial, and data protection requirements. Business partners and third-party service providers expect secure collaboration, well-defined security responsibilities, and protection of shared information. Cloud service providers, including Microsoft 365 and AWS, require secure integration, appropriate access management, and adherence to the shared responsibility model. Auditors and certification bodies expect objective evidence demonstrating that the ISMS has been effectively implemented, maintained, and continually improved in accordance with ISO/IEC 27001:2022.

By understanding and addressing the needs and expectations of these interested parties, PaySwift Ltd strengthens its information security posture, enhances regulatory compliance, builds customer confidence, improves operational resilience, and increases its readiness for successful ISO/IEC 27001 certification.

Information Security Risk Assessment for PaySwift Ltd

Introduction

PaySwift Ltd is a fintech company that processes customer personal information, financial transactions, and cloud-based services. As a result, the organization faces a variety of information security risks that could impact the confidentiality, integrity, and availability of its information assets.

Since PaySwift Ltd has not previously implemented a formal **Information Security Management System (ISMS)**, identifying and assessing these risks is an essential first step toward achieving **ISO 27001 certification**. This assessment identifies the major information security risks facing the organization and provides a foundation for implementing appropriate security controls.

Information Security Risk Register

Risk ID	Risk Description	Threat Source	Vulnerability	Likelihood	Impact
1	Phishing attacks targeting employees	Cybercriminals	Employees may be deceived into revealing credentials due to insufficient security awareness training.	High	High

Click to view full [Risk Register](#)

Risk Assessment Summary

The assessment indicates that PaySwift Ltd faces several significant information security risks due to its handling of sensitive customer and financial information, reliance on cloud infrastructure, and support for remote and hybrid working.

The highest-priority risks include:

- Phishing attacks targeting employees
- Weak or reused passwords
- Data leakage from remote and hybrid working
- Unauthorized access to customer information
- Cloud infrastructure misconfiguration

These risks could result in:

- Financial loss
- Regulatory penalties
- Operational disruption
- Loss of customer trust
- Reputational damage

Recommended Security Controls

To reduce the identified risks, PaySwift Ltd should implement a comprehensive **Information Security Management System (ISMS)** aligned with **ISO 27001**.

The following security controls are recommended:

- Multi-Factor Authentication (MFA)
- Strong password policies
- Security awareness and phishing training
- Role-Based Access Control (RBAC)
- Regular vulnerability assessments
- Secure cloud configuration management
- Endpoint protection and anti-malware solutions
- Encryption of sensitive data at rest and in transit
- Backup and disaster recovery procedures
- Continuous security monitoring
- Regular internal audits and compliance reviews

Conclusion

Implementing these controls will significantly strengthen PaySwift Ltd's information security posture by reducing the likelihood and impact of cyber threats.

A structured ISMS based on ISO 27001 will improve the organization's ability to protect sensitive information, enhance business resilience, support regulatory compliance, and build customer confidence. Achieving ISO 27001 certification within the planned twelve-month timeframe will demonstrate PaySwift Ltd's commitment to maintaining internationally recognized information security standards.

Information Security Risk Treatment Plan for PaySwift Ltd

Introduction

Following the identification and assessment of information security risks, PaySwift Ltd must determine the most appropriate treatment strategy for each identified risk. In line with **ISO/IEC 27001**, risk treatment decisions must consider risk likelihood and impact, organizational risk appetite, legal and regulatory requirements, implementation costs, and business objectives.

The available risk treatment options include:

- **Mitigate:** Implement controls to reduce the likelihood or impact of a risk.
- **Accept:** Retain the risk where it is within the organization's acceptable risk level.
- **Transfer:** Share or transfer part of the risk to another party through agreements, insurance, or external services.
- **Avoid:** Eliminate the activity or process that creates the risk.

The following treatment decisions have been selected for PaySwift Ltd's identified information security risks.

Risk Treatment Decisions

Risk	Treatment Strategy	Reasoning and Treatment Approach
Phishing attacks targeting employees	Mitigate	Phishing may result in credential theft and unauthorized access to sensitive systems. Security awareness training, email filtering, and multi-factor authentication (MFA) will reduce the likelihood of successful attacks while maintaining business operations.
Weak or reused passwords	Mitigate	Weak passwords increase the risk of account compromise. Strong password policies, MFA, and password management solutions will reduce unauthorized access risks to an acceptable level.

Cloud infrastructure misconfiguration	Mitigate	AWS hosts critical applications and customer data, making configuration errors a high-impact risk. Secure configuration standards, regular security reviews, and automated cloud monitoring will reduce the risk of data exposure.
Unauthorized access to customer information	Mitigate	Protecting customer information is a legal, regulatory, and business requirement. Role-based access control (RBAC), least-privilege access, MFA, and access reviews will reduce unauthorized access while supporting business activities.
Malware or ransomware infection	Mitigate	Malware can disrupt operations and cause financial losses. Endpoint protection, email filtering, software updates, employee awareness training, and tested backups will reduce both likelihood and impact.
Insider threats	Mitigate	Insider risks cannot be fully eliminated because employees require access to information. Access controls, monitoring, segregation of duties, and security awareness programmes will reduce accidental or intentional misuse.
Third-party vendor compromise	Transfer	Some risks originate from external providers and cannot be completely controlled by PaySwift Ltd. Vendor agreements, service level agreements (SLAs), cyber insurance, and supplier security requirements will transfer part of the operational and financial risk.
Data leakage from remote or hybrid working	Mitigate	Remote working increases exposure to insecure networks and lost devices. Encryption, VPN access, endpoint management, MFA, and remote working policies will reduce the risk of sensitive data exposure.
DDoS attack on the mobile application	Transfer	Completely preventing DDoS attacks is not practical due to their external nature. Cloud-based DDoS protection services and AWS security capabilities will transfer operational responsibility while maintaining service availability.

Loss or theft of company laptops or mobile devices	Mitigate	Portable devices increase the risk of data exposure if lost or stolen. Full-disk encryption, remote wipe capability, device management solutions, and strong authentication will reduce the impact of device loss.
Software vulnerabilities due to delayed patching	Mitigate	Attackers frequently exploit unpatched systems. A formal patch management process, vulnerability scanning, and regular software updates will reduce the likelihood of successful exploitation.
Accidental deletion or corruption of business data	Accept	While accidental deletion cannot be completely prevented, reliable backups and recovery procedures reduce the impact. The remaining risk is considered acceptable because restoring data from backups limits business disruption.

Risk Treatment Summary

The majority of identified risks have been assigned the **Mitigate** treatment strategy because they involve customer information, financial transactions, and critical cloud infrastructure that are essential to PaySwift Ltd's operations.

Implementing preventive, detective, and corrective security controls supports ISO 27001 requirements and helps protect the:

- **Confidentiality** of sensitive information
- **Integrity** of business and customer data
- **Availability** of critical systems and services

Risks involving **third-party providers and large-scale external attacks**, such as DDoS incidents, are more appropriately managed through the **Transfer** strategy. These risks can be partially transferred through supplier agreements, cloud security services, Service Level Agreements (SLAs), and cyber insurance.

The risk associated with **accidental deletion or corruption of business data** has been accepted because effective backup and recovery processes reduce the residual risk to an acceptable level. Additional controls may not provide sufficient value compared with their cost and operational impact.

Conclusion

PaySwift Ltd's Risk Treatment Plan demonstrates a balanced and practical approach to managing information security risks. Treatment decisions have been selected based on the nature of each risk, potential business impact, regulatory obligations, available security controls, and cost-effectiveness.

By implementing the recommended controls, PaySwift Ltd will strengthen its security posture, improve resilience against cyber threats, protect sensitive customer and financial information, and support the successful implementation of an ISO 27001-aligned Information Security Management System (ISMS).

Selection of ISO/IEC 27001:2022 Annex A Controls PaySwift Ltd

Introduction

As a fintech organization that processes customer personal information, financial transactions, and cloud-based services, PaySwift Ltd requires effective information security controls to protect its systems, data, and business operations.

The following **ISO/IEC 27001:2022 Annex A controls** have been selected based on the organization's highest-priority information security risks. These controls support PaySwift Ltd's objective of establishing a strong Information Security Management System (ISMS) and achieving ISO 27001 certification.

Selected Annex A Controls

ISO/IEC 27001:2022 Control	Why It Is Needed	Risks Addressed	Impact If Not Implemented
A.5.1 – Policies for Information Security	Establishes the organization's overall information security direction, responsibilities, and security expectations.	Weak governance, inconsistent security practices, insider threats.	Employees may follow inconsistent security procedures, increasing security incidents and the likelihood of ISO 27001 non-compliance.
A.5.15 – Access Control	Ensures users only access information and systems required for their job responsibilities.	Unauthorized access, insider threats, data breaches.	Unauthorized users may access confidential customer information, resulting in financial loss, regulatory penalties, and reputational damage.
A.5.16 – Identity Management	Ensures users are uniquely identified and accounts are properly managed throughout their lifecycle.	Compromised accounts, weak authentication, unauthorized access.	Shared or unmanaged accounts may prevent effective monitoring and increase the risk of unauthorized activities.

A.5.17 – Authentication Information	Protects passwords and authentication credentials through secure management practices.	Weak passwords, credential theft, phishing attacks.	Attackers may compromise accounts using stolen or weak credentials, leading to unauthorized system access.
A.5.23 – Information Security for Use of Cloud Services	Establishes security requirements for cloud platforms such as AWS and Microsoft 365.	Cloud misconfiguration, third-party risks, data exposure.	Sensitive customer data may be exposed due to insecure cloud configurations or inadequate cloud security oversight.
A.5.24 – Information Security Incident Management Planning and Preparation	Ensures the organization can detect, report, respond to, and recover from security incidents.	Malware, ransomware, phishing, data breaches.	Poor incident response may increase downtime, financial losses, operational disruption, and regulatory consequences.
A.6.3 – Information Security Awareness, Education and Training	Provides employees with knowledge of security threats, policies, and their responsibilities.	Phishing attacks, social engineering, insider threats, human error.	Employees may unintentionally expose sensitive information through unsafe practices or successful phishing attempts.
A.8.8 – Management of Technical Vulnerabilities	Requires identification, assessment, and remediation of technical vulnerabilities through patching and monitoring.	Software vulnerabilities, malware exploitation, cyberattacks.	Attackers may exploit known weaknesses to gain unauthorized access or disrupt business operations.
A.8.9 – Configuration Management	Ensures systems, applications, and cloud resources are securely configured and maintained.	Cloud misconfiguration, unauthorized changes, system weaknesses.	Incorrect configurations may expose sensitive information or create exploitable security vulnerabilities.

A.8.13 – Information Backup	Ensures critical business information and transaction records can be restored following loss, ransomware, or system failure.	Data loss, ransomware, accidental deletion, system failure.	Permanent loss of customer and business information may disrupt operations, reduce customer confidence, and lead to regulatory penalties.
------------------------------------	--	---	---

Control Selection Summary

The selected Annex A controls focus on the areas presenting the greatest information security risks to PaySwift Ltd. Priority has been given to controls covering:

- Information security governance
- Access management
- Identity and authentication protection
- Cloud security
- Incident response
- Employee security awareness
- Vulnerability management
- Secure system configuration
- Data backup and recovery

These controls directly support the protection of customer information, financial transactions, and cloud-based infrastructure.

The selected controls also strengthen the three fundamental principles of information security, known as the **CIA Triad**:

Confidentiality

Confidentiality is strengthened through:

- Access control
- Identity management
- Authentication security
- Cloud security controls

These measures ensure that sensitive customer and business information is only available to authorized users.

Integrity

Integrity is maintained through:

- Information security policies
- Configuration management
- Vulnerability management

These controls help prevent unauthorized changes, data manipulation, and system weaknesses.

Availability

Availability is supported through:

- Incident management planning
- Backup and recovery procedures
- Effective response processes

These controls ensure that critical services remain operational and can recover quickly from security incidents.

Conclusion

Implementing the selected ISO/IEC 27001:2022 Annex A controls will significantly reduce PaySwift Ltd's exposure to cybersecurity threats and strengthen the organization's overall security posture.

These controls will help the company:

- Protect sensitive customer and financial information
- Improve resilience against cyber threats
- Strengthen compliance with ISO/IEC 27001:2022 requirements
- Enhance customer trust and confidence
- Support successful ISO 27001 certification within the planned twelve-month timeframe

The selected controls provide a practical and risk-based foundation for developing an effective Information Security Management System (ISMS) that supports PaySwift Ltd's long-term security and business objectives.

Statement of Applicability (SoA)

Introduction

The **Statement of Applicability (SoA)** is a key document within PaySwift Ltd's Information Security Management System (ISMS). It identifies the **ISO/IEC 27001:2022 Annex A controls** that are applicable to the organization, provides justification for their selection, and defines their current implementation status.

PaySwift Ltd is a fintech organization providing mobile payment services and processing sensitive customer personal information and transaction records. Due to the critical nature of its operations, the organization requires effective information security controls to protect the **confidentiality, integrity, and availability** of its information assets.

The selected controls have been determined based on:

- Information security risk assessments
- Business requirements
- Regulatory obligations
- Protection of customer and financial information
- The objective of achieving ISO/IEC 27001 certification within twelve months

Statement of Applicability

Annex A Control	Control Name	Applicable	Justification for Inclusion	Implementation Status
A.5.1	Policies for Information Security	Yes	Formal information security policies are required to establish security responsibilities, governance processes, and consistent security practices across PaySwift Ltd.	Planned / To Be Implemented

A.5.15	Access Control	Yes	PaySwift Ltd manages sensitive customer and transaction information. Access restrictions ensure employees only access information required for their roles.	Planned / To Be Implemented
A.5.16	Identity Management	Yes	User identities across Microsoft 365, AWS, and internal systems must be properly created, managed, monitored, and removed when no longer required.	Planned / To Be Implemented
A.5.17	Authentication Information	Yes	Strong authentication controls are necessary to protect accounts against phishing, password theft, and unauthorized access.	Planned / To Be Implemented
A.5.23	Information Security for Use of Cloud Services	Yes	PaySwift Ltd relies on AWS cloud infrastructure and Microsoft 365 services. Cloud security controls are required to prevent data exposure and configuration weaknesses.	Planned / To Be Implemented
A.5.24	Information Security Incident Management Planning and Preparation	Yes	As a fintech company processing financial transactions, PaySwift Ltd requires effective incident response capabilities to detect, respond to, and recover from security incidents.	Planned / To Be Implemented
A.6.3	Information Security Awareness, Education and Training	Yes	Employees, including remote and hybrid workers, face threats such as phishing and social engineering. Security training reduces human-related risks.	Planned / To Be Implemented

A.8.8	Management of Technical Vulnerabilities	Yes	Applications and cloud systems may contain vulnerabilities. Regular vulnerability identification, assessment, and remediation reduce cyber risks.	Planned / To Be Implemented
A.8.9	Configuration Management	Yes	Secure configuration of AWS infrastructure, Microsoft 365, applications, and devices is required to prevent misconfiguration-related incidents.	Planned / To Be Implemented
A.8.13	Information Backup	Yes	Customer information, transaction records, and business data require reliable backups to support recovery from data loss, ransomware, and system failures.	Planned / To Be Implemented

Excluded Annex A Controls

Based on the current information security risk assessment, no controls within the selected scope have been excluded.

The selected controls are considered necessary due to PaySwift Ltd's:

- Processing of customer personal and financial information
- Dependence on cloud-based services
- Use of remote and hybrid working arrangements
- Requirement to maintain availability of mobile payment services
- Objective of achieving ISO/IEC 27001 certification

Any future exclusion of Annex A controls will be formally documented with a business justification and reviewed during ISMS management reviews.

Control Implementation Approach

PaySwift Ltd will implement the selected Annex A controls through a structured ISMS improvement programme. Key implementation activities include:

- Developing and approving formal information security policies
- Implementing role-based access controls and least-privilege principles

- Enforcing multi-factor authentication (MFA) across critical systems
- Establishing secure cloud configuration standards
- Conducting employee information security awareness training
- Implementing vulnerability scanning and patch management processes
- Establishing incident response and reporting procedures
- Testing backup and recovery procedures regularly

Conclusion

The selected ISO/IEC 27001:2022 Annex A controls represent the security measures most relevant to PaySwift Ltd's operational environment and risk profile.

These controls directly address the organization's key information security risks, including:

- Unauthorized access
- Phishing attacks
- Cloud security weaknesses
- Data loss
- Malware threats
- Human error

By implementing these controls, PaySwift Ltd will establish a strong foundation for its Information Security Management System, improve protection of customer and financial information, support regulatory compliance, and increase readiness for ISO/IEC 27001 certification.

The Statement of Applicability provides a clear roadmap for managing information security risks and demonstrates the organization's commitment to maintaining effective security governance and continuous improvement.

Information Security Objectives for PaySwift Ltd

Introduction

In accordance with **ISO/IEC 27001:2022**, information security objectives must support an organization's business goals and the effectiveness of its Information Security Management System (ISMS).

To ensure effective monitoring and evaluation, objectives should follow the **SMART principle**:

- **Specific** – Clearly defined and focused on a particular outcome.
- **Measurable** – Progress can be tracked using defined success criteria.
- **Achievable** – Realistic and attainable within available resources.
- **Relevant** – Supports business and security priorities.
- **Time-bound** – Includes a defined completion timeframe.

The following information security objectives have been developed based on PaySwift Ltd's role as a fintech organization that processes customer personal information, handles financial transactions, and operates within Microsoft 365 and AWS cloud environments.

Information Security Objectives

Objective	Measurement / Success Criteria	Target Completion
1. Implement Multi-Factor Authentication (MFA) for all employees and administrators accessing Microsoft 365, AWS, and other critical business systems.	100% of employee and administrator accounts protected by MFA, verified through access management reports.	Within 6 months
2. Reduce successful phishing-related security incidents by 50% through employee awareness training and phishing simulation exercises.	Compare successful phishing incidents before and after implementation, achieving at least a 50% reduction.	Within 12 months

3. Establish a formal vulnerability management and patch management programme to ensure critical vulnerabilities are remediated promptly.	95% of critical vulnerabilities patched within 14 days of identification, measured through vulnerability scan reports.	Within 9 months
4. Develop, implement, and test business continuity and backup procedures to protect critical customer and transaction data.	Complete backup implementation and conduct at least two successful disaster recovery tests with 100% recovery success for critical systems.	Within 12 months
5. Achieve ISO/IEC 27001:2022 certification by implementing an effective Information Security Management System (ISMS).	Completion of internal audits, management reviews, corrective actions, and successful certification by an accredited certification body.	Within 12 months

Explanation of Objectives

Objective 1: Implement Multi-Factor Authentication (MFA)

This objective strengthens access security by requiring users to provide an additional authentication factor when accessing critical business systems. MFA reduces the risk of unauthorized access caused by stolen, compromised, or weak passwords.

By implementing MFA across Microsoft 365, AWS, and other important platforms, PaySwift Ltd will significantly improve account protection and reduce the likelihood of identity-based attacks.

Objective 2: Reduce Phishing-Related Security Incidents

Human error remains one of the most common causes of security incidents. Regular information security awareness training and phishing simulation exercises will improve employees' ability to identify, avoid, and report phishing attempts.

Reducing successful phishing attacks will help protect customer information, prevent credential theft, and strengthen the organization's overall security culture.

Objective 3: Improve Vulnerability and Patch Management

Unpatched software vulnerabilities create opportunities for attackers to compromise systems. Establishing a formal vulnerability and patch management process will ensure that security weaknesses are identified, assessed, and resolved within appropriate timeframes.

Regular vulnerability scanning and timely patching will improve the security of PaySwift Ltd's cloud infrastructure, applications, and business systems.

Objective 4: Strengthen Backup and Business Continuity

Reliable backup procedures and tested disaster recovery plans ensure that critical customer information and payment services can be restored quickly following cyber incidents, system failures, or accidental data loss.

Regular recovery testing will help confirm that PaySwift Ltd can maintain business operations and minimize disruption during security events.

Objective 5: Achieve ISO/IEC 27001 Certification

Implementing an effective ISMS and achieving ISO/IEC 27001 certification demonstrates PaySwift Ltd's commitment to information security, regulatory compliance, and continual improvement.

Certification will increase customer confidence, strengthen stakeholder trust, and provide assurance that information security risks are being managed through internationally recognized best practices.

Conclusion

The information security objectives established for PaySwift Ltd are aligned with the organization's business operations, risk profile, and strategic goal of achieving ISO/IEC 27001 certification.

Each objective is designed to be specific, measurable, achievable, relevant, and time-bound, allowing management to monitor progress and continually improve the effectiveness of the ISMS.

Successful achievement of these objectives will strengthen PaySwift Ltd's ability to:

- Protect sensitive customer and financial information
- Maintain secure and reliable payment services
- Reduce exposure to cyber threats
- Improve regulatory compliance
- Support sustainable business growth

These objectives provide a clear roadmap for enhancing PaySwift Ltd's information security maturity and achieving long-term operational resilience.

ISO/IEC 27001 Certification Audit Preparation for PaySwift Ltd

Introduction

With an **ISO/IEC 27001 certification audit** scheduled within one month, PaySwift Ltd must collect and maintain documented evidence demonstrating that its **Information Security Management System (ISMS)** has been established, implemented, maintained, and is operating effectively.

Audit evidence must demonstrate compliance with **ISO/IEC 27001:2022 requirements** and confirm that appropriate **Annex A security controls** have been implemented to manage identified information security risks.

The following evidence has been identified as essential for the certification audit.

Required Audit Evidence

Evidence Required	Purpose of Evidence	Importance	ISO/IEC 27001 Requirement / Control Demonstrated
1. Information Security Policy	Approved policy defining security objectives, responsibilities, and the organization's commitment to information security.	Demonstrates management commitment and provides the foundation for the ISMS.	Clause 5.2 – Information Security Policy; Annex A A.5.1 – Policies for Information Security
2. ISMS Scope Document	Document defining the boundaries, applicability, systems, processes, people, and information assets included within the ISMS.	Confirms the scope and coverage of the organization's security management system.	Clause 4.3 – Determining the Scope of the ISMS

3. Risk Assessment and Risk Register	Documentation identifying information security risks, evaluating their likelihood and impact, and assigning risk levels.	Demonstrates that information security risks have been systematically identified and assessed.	Clause 6.1.2 – Information Security Risk Assessment
4. Risk Treatment Plan and Statement of Applicability (SoA)	Documents selected risk treatments and applicable Annex A controls, including justification for their selection.	Demonstrates how identified risks are managed and why specific controls have been implemented.	Clause 6.1.3 – Information Security Risk Treatment; Statement of Applicability
5. User Access Review Records	Records of periodic reviews of user accounts, permissions, and access rights across Microsoft 365, AWS, and business applications.	Confirms that access is controlled, reviewed regularly, and limited to authorized personnel.	Annex A A.5.15 – Access Control; A.5.16 – Identity Management; A.5.17 – Authentication Information
6. Information Security Awareness Training Records	Employee training attendance records, awareness materials, and phishing simulation results.	Demonstrates that employees understand security responsibilities and can identify security threats.	Annex A A.6.3 – Information Security Awareness, Education and Training
7. Incident Management Records	Security incident reports, investigation records, response activities, and lessons learned.	Shows that security incidents are identified, managed, investigated, and resolved effectively.	Annex A A.5.24 – Information Security Incident Management Planning and Preparation
8. Vulnerability Assessment and Patch Management Reports	Vulnerability scan results, identified weaknesses, and records of completed security updates.	Demonstrates proactive identification and remediation of technical vulnerabilities.	Annex A A.8.8 – Management of Technical Vulnerabilities
9. Backup and Disaster Recovery Test Records	Backup schedules, restoration test results, and disaster recovery exercise reports.	Confirms that critical information can be restored following data loss, ransomware, or system failure.	Annex A A.8.13 – Information Backup

10. Internal Audit and Management Review Records	Internal audit reports, corrective actions, meeting records, and management review outcomes.	Demonstrates continual improvement, leadership oversight, and evaluation of ISMS effectiveness.	Clause 9.2 – Internal Audit; Clause 9.3 – Management Review
---	--	---	---

Importance of Audit Evidence

The evidence collected provides objective proof that PaySwift Ltd's Information Security Management System has been properly implemented and is functioning effectively. During the certification audit, auditors will review documented information to verify that PaySwift Ltd has:

- Identified and assessed information security risks
- Implemented appropriate security controls
- Trained employees on information security responsibilities
- Monitored security performance
- Established processes for continual improvement

Complete and accurate evidence demonstrates that security controls are operating in practice rather than existing only as documented procedures. Maintaining reliable audit evidence increases confidence that PaySwift Ltd can effectively protect:

- Customer personal information
- Financial transaction data
- Cloud-based services
- Critical business systems

while meeting ISO/IEC 27001:2022 requirements.

Conclusion

Preparing complete and accurate audit evidence is a critical step toward achieving **ISO/IEC 27001 certification**. The identified evidence covers the key areas required for an effective ISMS, including:

- Information security governance
- Risk management
- Access control
- Employee awareness
- Incident management
- Vulnerability management

- Backup and recovery
- Internal auditing
- Management review

By maintaining current and accurate evidence, PaySwift Ltd will demonstrate compliance with ISO/IEC 27001:2022, support a successful certification audit, and reinforce its commitment to protecting sensitive information and maintaining customer trust.

Internal ISO/IEC 27001 Auditor Assessment for PaySwift Ltd

Introduction

As the Internal ISO/IEC 27001 Auditor, a review of PaySwift Ltd's Information Security Management System (ISMS) was conducted based on the available organizational information. The purpose of this assessment is to identify potential **nonconformities, observations, and opportunities for improvement** before the planned ISO/IEC 27001 certification audit.

The findings are intended to help PaySwift Ltd address weaknesses, strengthen its ISMS, and improve overall certification readiness.

Potential Nonconformities

Potential Nonconformity	Why It Is a Concern	Certification Readiness Impact
1. No formally implemented ISMS	PaySwift Ltd has grown rapidly but has not previously established a formal ISMS. ISO/IEC 27001 requires a documented and operational management system.	Major concern. The organization may be unable to achieve certification unless the ISMS is fully implemented and operating before the audit.
2. Information security policies may not be formally approved and communicated	Employees require documented policies to understand security responsibilities and organizational expectations.	Missing or incomplete policies may result in audit nonconformities.
3. Risk assessment and treatment processes are not fully operational	ISO/IEC 27001 requires organizations to identify, assess, and treat information security risks using a defined methodology.	Auditors may determine that security controls are not adequately supported by a structured risk management process.
4. Internal audit programme has not been completed	Internal audits are required to evaluate ISMS effectiveness and identify corrective actions before certification.	Failure to complete internal audits may demonstrate non-compliance and significantly reduce certification readiness.

5. Management reviews have not been formally conducted	Senior management must review ISMS performance and effectiveness to support continual improvement.	Absence of management review records may result in a nonconformity because leadership involvement cannot be demonstrated.
---	--	---

Observations

Observation	Why It Is a Concern	Certification Readiness Impact
1. Heavy reliance on AWS cloud infrastructure	Cloud environments require continuous monitoring and secure configuration to prevent unauthorized access and data exposure.	Auditors are likely to request evidence that cloud security is actively managed and regularly reviewed.
2. Remote and hybrid working increases security risks	Employees may access systems through insecure networks or devices if appropriate controls are not enforced.	Additional evidence will be required to demonstrate secure remote working arrangements.
3. Customer and financial transaction data are highly sensitive	Fintech organizations face increased cybersecurity and regulatory expectations because of the sensitivity and value of information processed.	Strong technical and organizational controls will be expected during the certification audit.
4. Microsoft 365 is a critical business platform	Weak identity and access management could expose sensitive business information.	Auditors are likely to examine authentication, access controls, and security logging.
5. Rapid business growth may have outpaced security governance	Business expansion can result in inconsistent or undocumented security processes.	Additional evidence may be required to demonstrate consistent ISMS implementation across the organization.

Opportunities for Improvement

Opportunity for Improvement	Benefit	Certification Readiness Impact
1. Implement Security Information and Event Management (SIEM) monitoring	Centralized monitoring improves the ability to detect and respond to security incidents quickly.	Demonstrates a proactive approach to monitoring and continual improvement.
2. Conduct regular phishing simulation exercises	Practical exercises reinforce employee awareness and measure training effectiveness.	Provides measurable evidence of ongoing security awareness activities.
3. Introduce periodic access recertification	Regular reviews ensure users retain only the access necessary for their current roles.	Strengthens access control and demonstrates effective privilege management.
4. Perform regular cloud security configuration reviews	Routine assessments identify configuration weaknesses before they can be exploited.	Improves assurance that AWS and Microsoft 365 environments remain securely configured.
5. Develop an ISMS performance dashboard with KPIs	Tracking objectives, incidents, vulnerabilities, training, and audit findings supports informed management decisions.	Demonstrates monitoring, measurement, and continual improvement of the ISMS.

Audit Summary

The assessment indicates that PaySwift Ltd has made meaningful progress toward ISO/IEC 27001 implementation by identifying information security risks, selecting relevant Annex A controls, establishing information security objectives, and preparing supporting documentation.

However, several critical activities must be completed before the certification audit, particularly:

- Formal implementation and operation of the ISMS
- Approval and communication of information security policies
- Completion of the internal audit programme
- Formal management review
- Evidence that selected controls are operating effectively

The observations require particular attention because of PaySwift Ltd's fintech operations, cloud-based infrastructure, sensitive customer and financial information, and remote workforce.

The identified opportunities for improvement will further strengthen the ISMS, improve the organization's security posture, and demonstrate a commitment to continual improvement.

Conclusion

Based on the available information, **PaySwift Ltd is progressing toward ISO/IEC 27001 certification but is not yet fully prepared for the certification audit.**

Priority should be given to closing the identified potential nonconformities and ensuring that the ISMS is not only documented but also implemented, monitored, reviewed, and supported by objective evidence.

Addressing the identified gaps, reviewing the observations, and implementing the recommended improvements will significantly improve PaySwift Ltd's certification readiness and its ability to demonstrate effective compliance with **ISO/IEC 27001:2022** requirements.

Internal Auditor Recommendation for ISO/IEC 27001 Certification for PaySwift Ltd

Recommendation: Not Yet

Recommendation and Rationale

Based on the internal audit assessment, I do **not yet recommend PaySwift Ltd for ISO/IEC 27001:2022 certification**. Although the organization has made significant progress toward certification, several critical requirements have not yet been fully implemented or demonstrated.

PaySwift Ltd has only recently begun implementing its **Information Security Management System (ISMS)** after previously operating without a formal information security framework. As a result, the ISMS has not yet matured sufficiently to provide consistent objective evidence of effective operation.

Key governance activities still requiring completion include:

- Formal approval and communication of information security policies
- Full implementation of the risk assessment and risk treatment processes
- Completion of internal audits
- Formal management reviews
- Implementation and testing of selected Annex A controls
- Collection of sufficient operational evidence demonstrating control effectiveness

These activities are essential for demonstrating that the ISMS is functioning effectively, being monitored and reviewed, and supporting continual improvement.

Key Risk Considerations

PaySwift Ltd has identified several high-priority information security risks, including:

- Phishing attacks
- Weak or reused passwords
- Cloud infrastructure misconfiguration
- Unauthorized access
- Malware and ransomware
- Insider threats

- Data leakage from remote and hybrid working

Appropriate ISO/IEC 27001:2022 Annex A controls have been selected to address these risks. However, most controls remain in the **planned implementation stage**.

A certification auditor will expect objective evidence that relevant controls have been implemented, are operating effectively, and are being monitored and reviewed. Documentation alone will therefore not be sufficient to demonstrate full readiness.

Positive Progress Achieved

Despite the outstanding gaps, PaySwift Ltd has established a strong foundation for its ISMS. The organization has:

- Defined the scope of the ISMS.
- Identified relevant interested parties and their information security requirements.
- Completed an information security risk assessment and risk treatment plan.
- Selected relevant ISO/IEC 27001:2022 Annex A controls.
- Developed a Statement of Applicability (SoA).
- Established measurable information security objectives.
- Identified the documentation and evidence required for the certification audit.

These activities demonstrate management commitment and provide a structured foundation for completing the ISMS implementation.

Evidence Supporting the Recommendation

The “**Not Yet**” recommendation is primarily supported by the following internal audit findings:

1. PaySwift Ltd does not yet have a sufficiently mature and operational ISMS.
2. Internal audits have not yet been completed to verify ISMS effectiveness.
3. Formal management reviews have not yet been conducted and documented.
4. Several information security policies and procedures are still awaiting implementation and approval.
5. Most selected Annex A controls have not yet been fully implemented or tested.
6. Limited operational evidence is currently available to demonstrate control effectiveness over time.

These gaps should be addressed before the organization proceeds to the external certification audit.

Conclusion

In my opinion as the **Lead Internal Auditor**, PaySwift Ltd is progressing in the right direction toward ISO/IEC 27001 certification but is **not yet ready for the certification audit**.

The organization has completed much of the necessary planning and demonstrated a clear commitment to information security. However, certification should only be recommended once the ISMS has been fully implemented, relevant security controls have operated effectively for a reasonable period, internal audits and management reviews have been completed, and sufficient objective evidence is available to demonstrate compliance with ISO/IEC 27001:2022.

Once the outstanding actions have been completed and identified nonconformities have been addressed through effective corrective actions, PaySwift Ltd should be in a strong position to proceed confidently with the external ISO/IEC 27001 certification audit.